

IL CASO TEA

Tra strategie di marketing discutibili e noncuranza della sicurezza

Corso cybersecurity technician UC1 e UC2, 21/05/2026

COS'È TEA?

Tea era una app di dating per sole donne, in cui non si cercavano appuntamenti ma potenziali feedback negativi sugli uomini.

Non c'era praticamente alcun controllo sulla veridicità delle informazioni, quindi era probabile che informazioni vere si mischiassero a semplice gossip o vera e propria diffamazione.

L'app esisteva dal 2023 ma divenne la app N.1 dell'Apple store nel 2025.



ARE WE DATING THE SAME GUY?

Erano dei gruppi Facebook esistenti prima di Tea e con lo stesso scopo di proteggere le donne da potenziali catfish o red flags.

Il fondatore di Tea, Sean Cook, cercò di assumere Paola Sanchez, l'amministratrice di quei gruppi, al suo rifiuto i gruppi di "Are we dating the same guy" si riempirono di account che mandavano link di Tea e ne facevano pubblicità.

Vennero creati altri gruppi AWDTSG gestiti da Tea, anche il loro sito ufficiale aveva problemi di sicurezza. Tutti i dati delle influencers coinvolte erano leakabili aggiungendo "/admin" nella URL.

I DIFETTI DI SICUREZZA

- ▶ L'app è stata sviluppata da due programmatori brasiliani anonimi, Cook non sapeva programmare.
- ▶ Per dimostrare di essere una donna, e quindi poter usare la app, bisognava mandare una foto identificativa e un selfie, la promessa era che le foto sarebbero state eliminate subito dopo l'identificazione.
- ▶ Le foto erano salvate in un database a cui CHIUNQUE poteva accedere, inoltre agli utenti veniva assegnata una chiave API con cui si poteva anche accedere al backend del sito e inviare notifiche push a tutti gli altri.
- ▶ Come per i gruppi AWDTSO la URL era tranquillamente manipolabile.

GLI ATTACCHI

- ▶ Il 25 luglio 2025 viene reso ufficiale che Tea aveva subito un furto di dati e che circa 72.000 foto, tra cui 13.000 erano documenti di riconoscimento, ora erano di dominio pubblico
- ▶ Il 28 luglio si viene a sapere di un data leak ancora più pericoloso, in quanto erano stati leakati più di un milione di messaggi privati degli utenti, che potevano potenzialmente compromettere il loro anonimato.
- ▶ I dati leakati risalivano massimo a due anni prima, un portavoce di Tea ha dichiarato che le foto erano state conservate per rispettare una legge per la prevenzione del cyberbullismo.

COME HANNO FATTO?

- ▶ Il leak delle foto è stato un problema di configurazione del salvataggio in cloud, in pratica gli sviluppatori hanno lasciato i permessi di lettura del bucket Firebase come pubblici, nessun tipo di controllo. Bastava avere l'URL giusta per prendere quello che si voleva.
- ▶ Il leak dei messaggi privati è stato possibile perché l'endpoint delle API legacy era rimasto attivo e, anche questo, senza alcuna autenticazione. Chiunque avrebbe potuto usare questa falla per leggere tutte le chat che voleva.

POSSIBILE PREVENZIONE

- ▶ Le foto identificative andavano cancellate immediatamente, come in teoria promettevano di fare.
- ▶ Permessi di lettura dei bucket privati di default. L'accesso deve essere consentito solo con permessi autorizzati e temporanei (privilegio minimo).
- ▶ I database non più utilizzati vanno cancellati o almeno tenuti offline.
- ▶ Per le API usare le funzioni integrate nel linguaggio di programmazione usato, in modo che ignorino i tentativi di manomissione per concentrarsi solo sul nome del file.

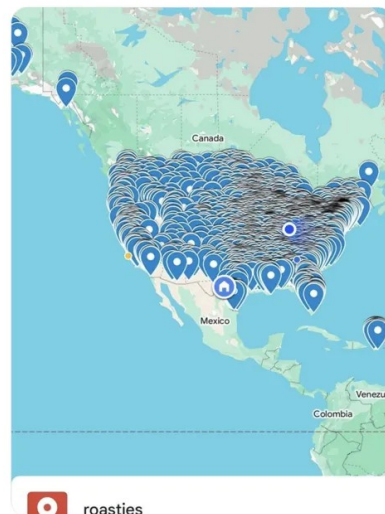
LE CONSEGUENZE

Subito dopo il primo leak venne creato un sito in cui venivano mostrate le foto degli utenti di Tea a coppie, e il visitatore poteva scegliere la sua preferita. Il sito venne chiuso poco tempo dopo.

Venne pubblicata una mappa con le posizioni di tutte le utenti vittime del leak, non si sa se sia autentica.

Tea è stata rimossa dallo store di Apple, ma è ancora presente su Google Play Store.

 **genddy** @ZTobias114838 · July 25, 2025
The drivers licenses leaked today from the tea app have been uploaded to a searchable map.... this may be the worst PII leak I've ever seen lol



The background features abstract, overlapping geometric shapes in various shades of blue, ranging from light sky blue to deep navy blue. These shapes are primarily located on the left and right sides of the slide, framing the central white area.

GRAZIE DELL'ATTENZIONE

Corso cybersecurity technician UC1 e UC2, 21/05/2026